1. Introduction

Application Programming Interfaces (APIs) are widely used in modern applications, including mobile apps, SaaS platforms, and cloud services. APIs allow different systems to communicate and exchange data efficiently.

However, insecure APIs can expose sensitive data, allow unauthorized access, or enable attackers to abuse system functionality.

This report presents a security analysis of selected public API endpoints using Postman. The goal is to identify potential security risks and provide recommendations to improve API security.

---

2. Objective

The objective of this task is to analyze publicly available API endpoints and identify potential security risks such as unauthenticated access, excessive data exposure, and predictable resource identifiers. The analysis also provides remediation suggestions to improve API security practices.

---

3. Tools Used

The following tools were used during the API security analysis:

- **Postman** – for sending API requests and inspecting responses
- **Browser DevTools** – for examining headers and response behavior
- **JSONPlaceholder Test API** – used as a demo API for testing

---

4. API Tested

The API used for this analysis is a public testing API.

Base URL:

https://jsonplaceholder.typicode.com

Endpoints tested:

/users
/posts
/comments

These endpoints were accessed using GET requests to observe the response data and analyze potential security risks.

---

5. Methodology

The API endpoints were tested using Postman by sending GET requests to retrieve available data.

The responses were analyzed to identify security risks such as:

- Missing authentication requirements
- Excessive exposure of data fields
- Predictable resource identifiers
- Public access to sensitive information

Screenshots were captured to document the API testing process.

---

6. Security Findings

Finding 1 – Unauthenticated Endpoint

Endpoint Tested

GET /users

Observation

The API endpoint returns user information without requiring authentication such as API keys, tokens, or login credentials.

Risk Severity

Medium

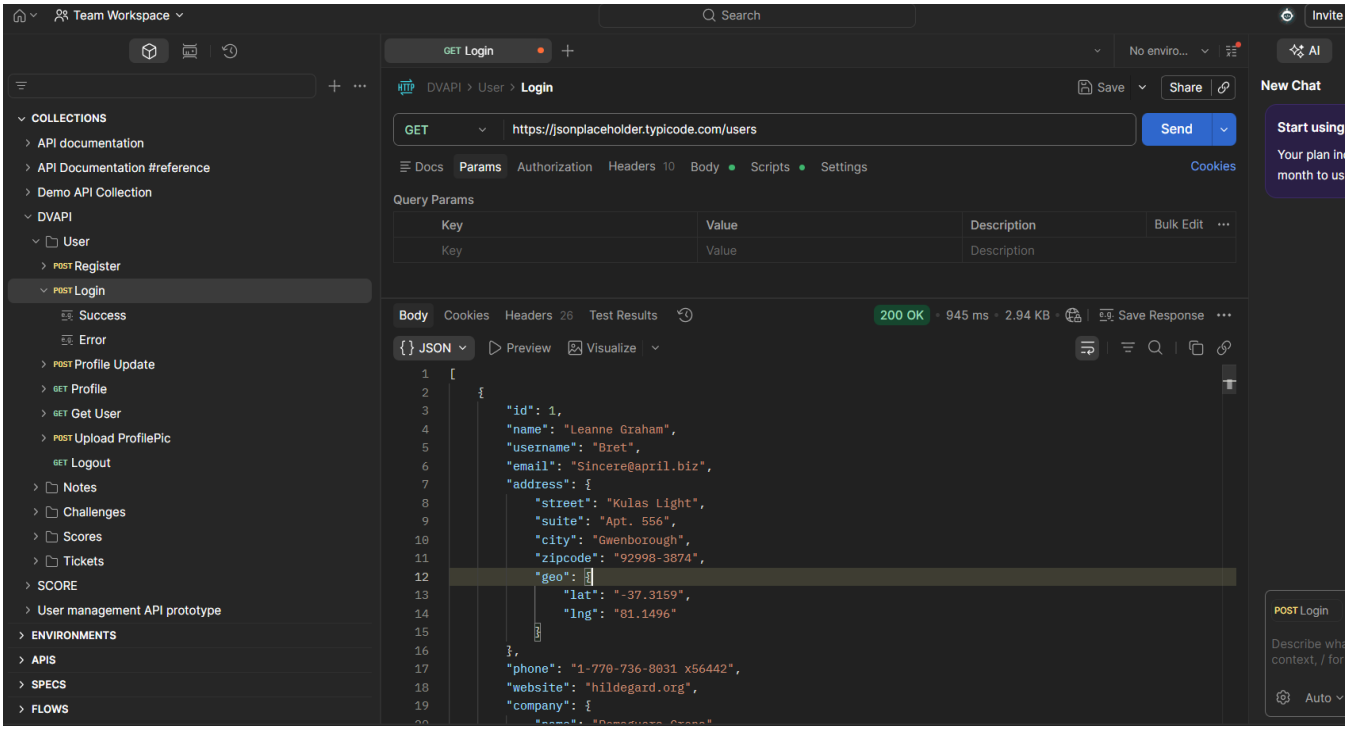
Business Impact

In a real production environment, attackers could collect user information such as email addresses and contact details without authorization.

Recommendation

Implement authentication mechanisms such as:

- API keys
- OAuth authentication
- JWT tokens



Finding 2 – Excessive Data Exposure

Endpoint Tested

GET /users

Observation

The API response contains multiple personal information fields including email address, phone number, address, and company information.

Risk Severity

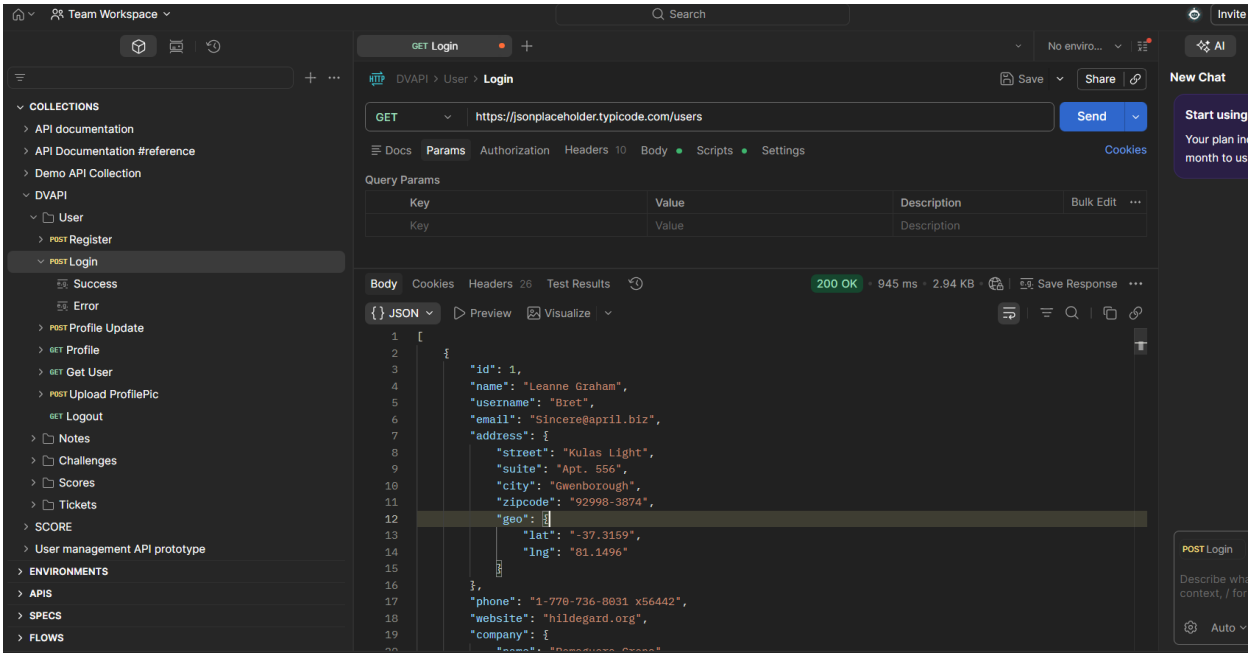
Medium

Business Impact

Exposure of personal information could lead to privacy violations or targeted phishing attacks.

Recommendation

Only return necessary data fields required by the application.



Finding 3 – Predictable Resource IDs

Endpoints Tested

GET /posts
GET /comments

Observation

The API uses sequential resource identifiers such as /posts/1, /posts/2, and /posts/3.

Risk Severity

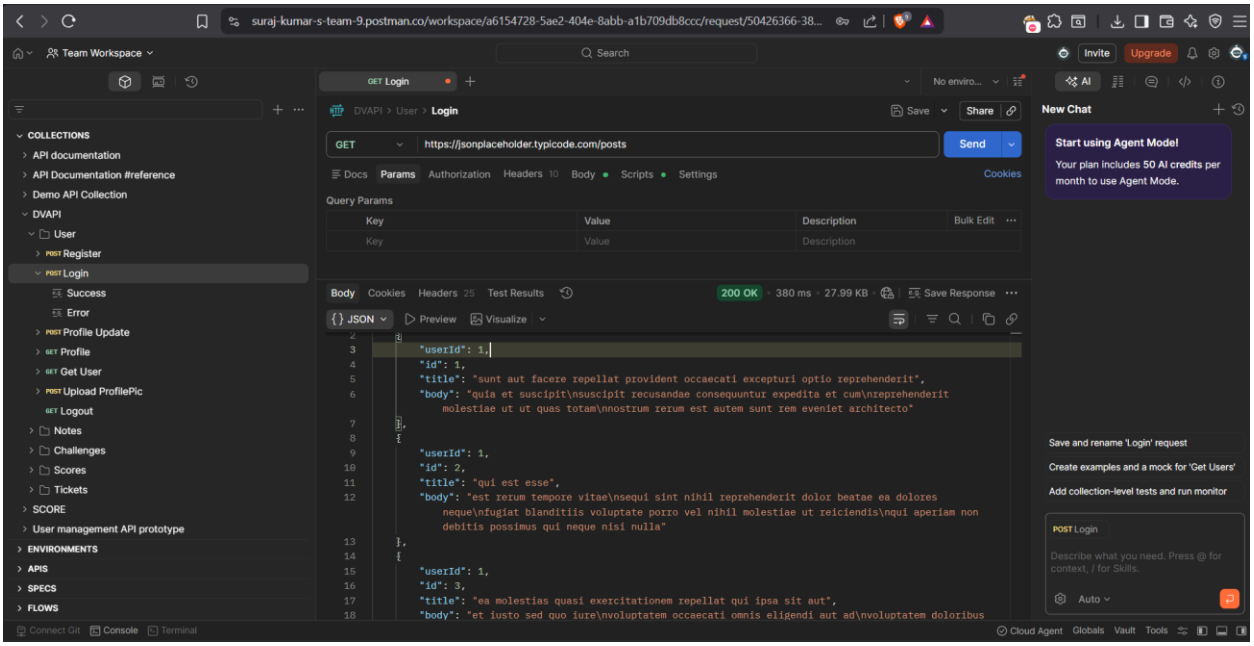
Low – Medium

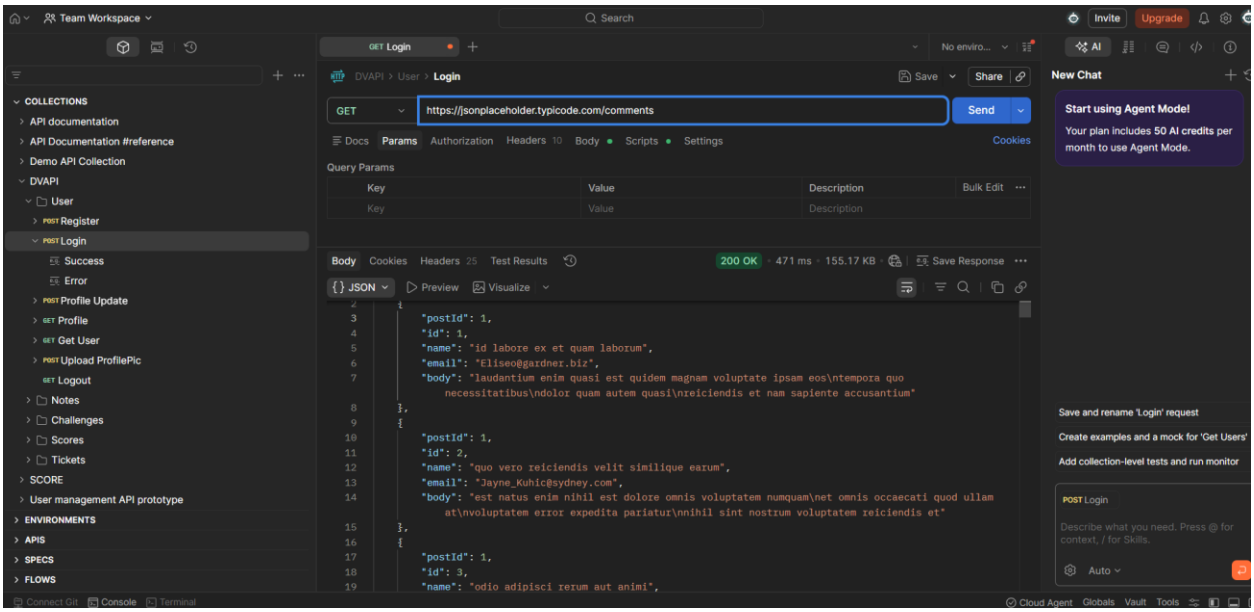
Business Impact

Attackers could automate requests to enumerate and collect large amounts of data.

Recommendation

Implement proper authorization checks and monitoring mechanisms to detect unusual API usage.





7. Security Recommendations

The following recommendations can improve API security:

- Implement strong authentication and authorization mechanisms
- Limit sensitive data exposure in API responses

- Apply rate limiting to prevent abuse
- Monitor API traffic for suspicious activity
- Validate input parameters to prevent injection attacks

---

8. Conclusion

This analysis demonstrates how APIs can expose sensitive information if proper security controls are not implemented. Although the tested API is designed for demonstration purposes, similar vulnerabilities in real-world applications could lead to unauthorized data access or system abuse.

Organizations should implement strong authentication, minimize data exposure, and monitor API activity to maintain secure API environments.